



HACK TRACK



with OffSec Student Mentors

Your fast track through PEN-200.

Introduction



Luigi Fiore (alias lypd0) - OffSec Student Mentor





Hacktrack: Active Directory Introduction & Enumeration



Presented by OffSec Student Mentors Team

Confidentiality Notice

This document and the information contained herein are confidential and proprietary to OffSec. It is provided solely for the HackTrack PEN-200 learners and may not be copied, reproduced, distributed, or disclosed in whole or in part to any third party without the prior written consent of OffSec. Unauthorized disclosure or distribution may be unlawful and subject to legal action.



Agenda

- Introduction to Active Directory & Enumeration
 - What is it, and how does it work?
 - What is a domain and objects?
 - How permissions are managed
 - Enumeration: Unauthenticated & Authenticated
 - Automated Enumeration
- Closing with Q&A



Example: Home/Cafe - Decentralized Network





Example: Hardened Company - Centralized Network with Policies



Network Admin (boss)



Password Policy



AppLocker Policy



Device Installation
Restrictions



Centralized Network with Policies



Network
Admin (boss)



Decide who accesses the private centralized network



Decide which user can perform which action

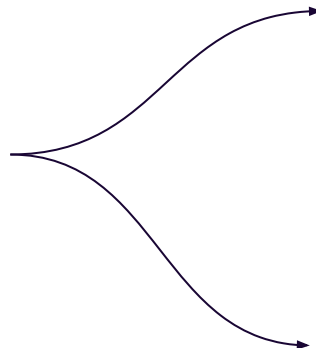


Integrate hardened policies to reduce risk

Lightweight Directory Access Protocol (LDAP)



LDAP is a protocol that allows system administrators to have a centralized network of objects.





Active Directory (AD)

Active Directory (AD), is a service that allows system administrators to update and manage objects on a large scale.



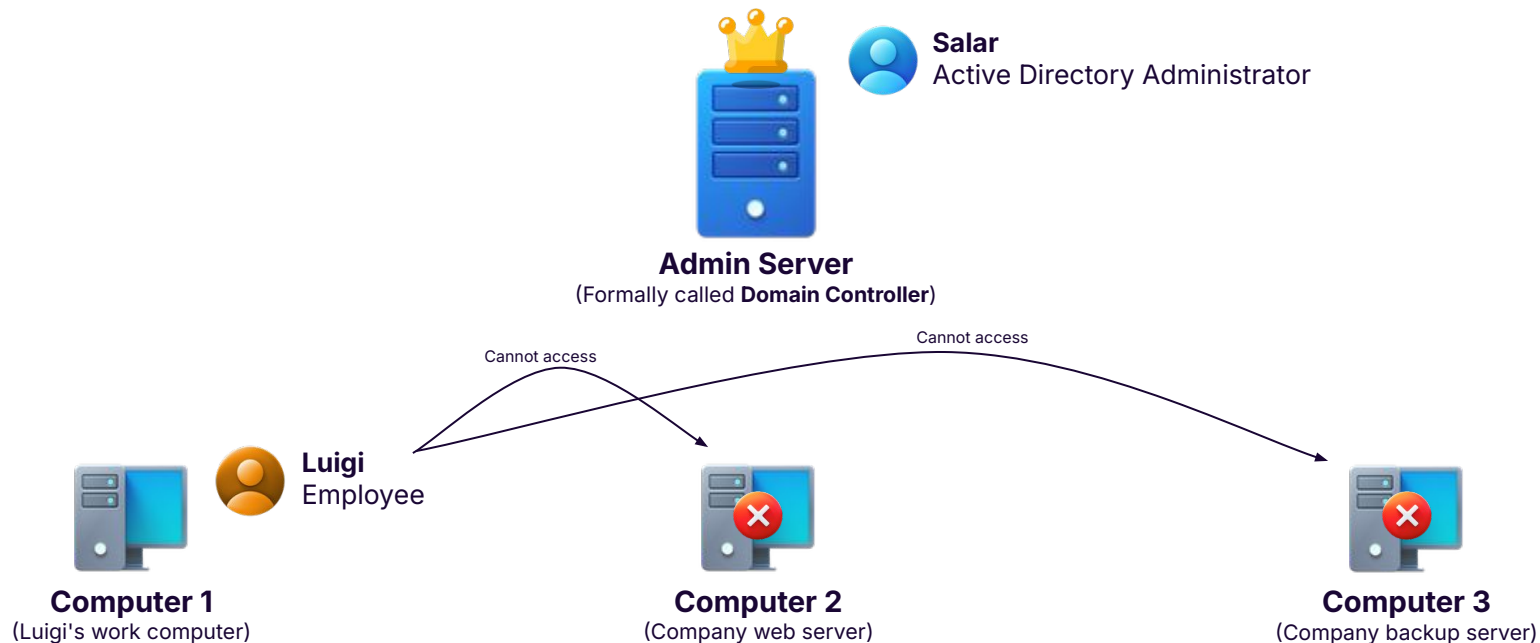
Active Directory (AD) terminology

The Centralized Network → **Domain**
(a logical boundary between network objects)

Anything Inside AD (Users, Groups, ACLs, Printers,
Computers, Group Policies, ...) → **Objects**



Active Directory (AD) inside the OffSec Domain





Active Directory (AD) inside the OffSec Network

" I want Luigi to help develop the new company website. Because of this, he needs access to the company's webserver "

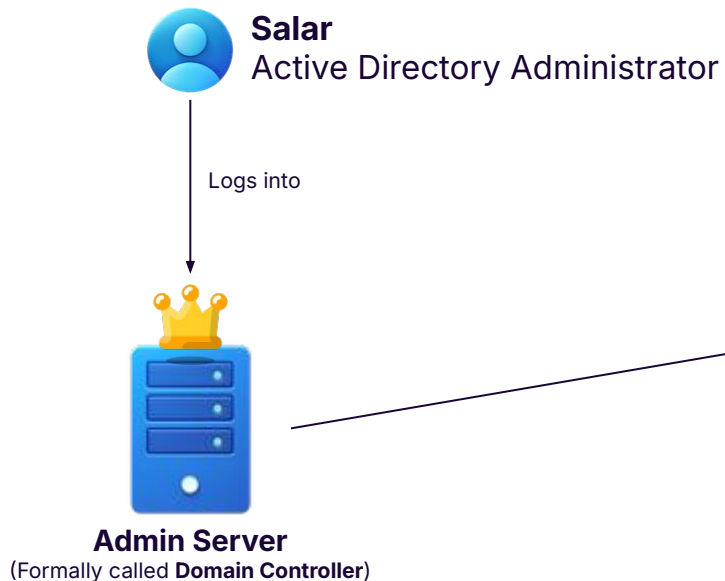


Salar

Active Directory Administrator



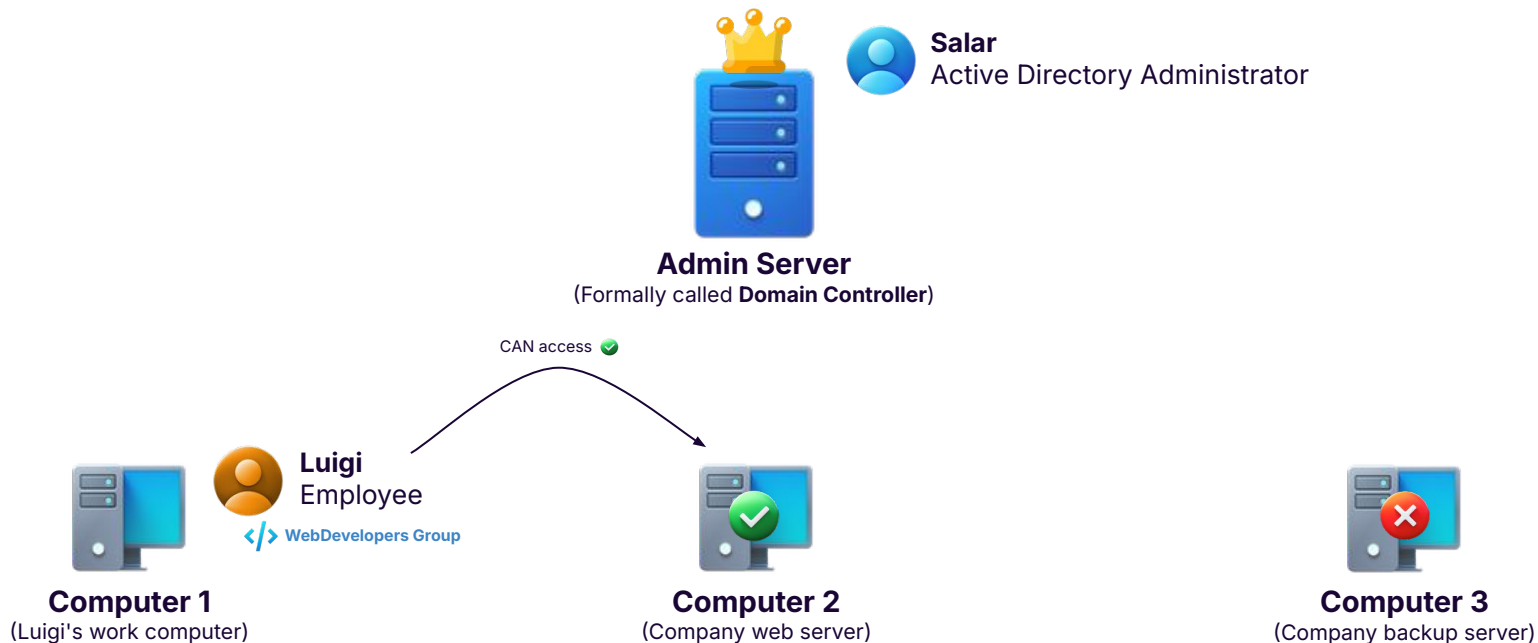
Active Directory (AD) inside the OffSec Network



```
Command Prompt
C:\> net localgroup WebDevelopers
Luigi /add /domain
```

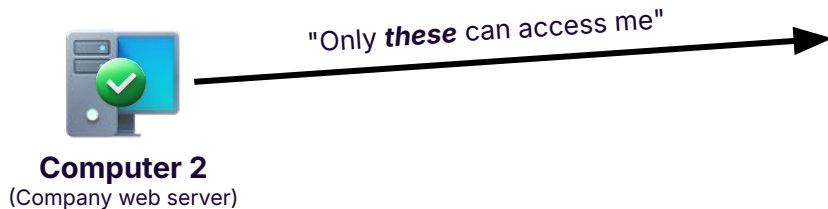


Active Directory (AD) inside the OffSec Network





Active Directory (AD) - Access Control Lists



Allowed To Access List:



Domain Administrators



Database Administrators



Web Developers



Active Directory (AD)

Active Directory (AD), is a service that allows system administrators to update and manage objects on a large scale.



Cheatsheet

Anonymous Enumeration

- **SMB:**

- `nxc smb <IP> -u '' -p ''`
- `enum4linux -a -u "" -p "" <IP>`

- **LDAP:**

- `ldapsearch -x -H LDAP://<DC IP> -s base`
- `ldapsearch -x -H ldap://<DC IP> -D '' -w '' -b "DC=corp,DC=com"`

- **Kerberos:**

- `kerbrute userenum --dc <DC IP> -d corp.com xato-net-10-million-usernames.txt`



Cheatsheet

Authenticated Enumeration - PowerView

- **Domain Information:** `Get-Domain`
- **User Information:** `Get-DomainUser -Properties * | select cn,description,title`
- **Group Information:** `Get-DomainGroup | select cn`
- **Group Memberships:** `Get-DomainGroupMember "Domain Admins"`
- **ACLs:**
 - `Find-InterestingDomainAcl`
 - `Invoke-ACLScanner`
 - **Targeted ACLs:** `Find-InterestingDomainAcl | ?{$_ .IdentityReferenceName -eq 'stephanie'} | select IdentityReferenceName,ActiveDirectoryRights,ObjectDN`
- **Computer Information:** `Get-DomainComputer -Domain "corp.com" | Resolve-IPAddress`
- **SPNs:** `Get-DomainUser -SPN`

Enumerating logged on users (PsLoggedon)

- `PsLoggedon.exe \\client75`



Appendix

- [PowerView](#)
- [BloodHound](#)
- [ACL Abuse Graph](#)
- [PoSLoggedon](#)
- [NetExec \(nxc\)](#)



Agenda (recap of the day)

- Introduction to Active Directory & Enumeration
 - What is it, and how does it work?
 - What is a domain and objects?
 - How permissions are managed
 - Enumeration: Unauthenticated & Authenticated
 - Automated Enumeration



Q & A



Survey

Link: <https://forms.gle/DhsZwNknVWNK65yy6>

THANK YOU

